

IT/IS Auditing Question Paper – Set 1

Q.No.1. When an organization decides to insure some of its assets, what type of risk mitigation method they are adopting?

- a) Risk Avoidance
- b) Risk Reduction
- c) Risk Transfer
- d) Risk Elimination

Q.No.2. which of the following is true about Auditing (Definition)?

- a) Helps in reducing the organization costs
- b) Assesment of Organization's internal policies, controls and process.
- c) Addresses the Risk exposure within IT systems.
- d) Defines better policies

Q.No.3 Which control classification attempts to repair the impact of a threat?

- a) Preventive
- b) Detective
- c) Deterrent
- d) Corrective

Q.No.4 Define Internal Controls?

- a) Control Tools used to detect risks
- b) Ensures proper functioning of processes within the company
- c) Defines the efficient Audit procedures
- d) Process in the Audit Planning

Q.No.5. Which of the following is the major step in the pre-audit preparation phase?

- a) Review the procedures followed
- b) Review organizations existing network diagram
- c) Arrange a meeting with the senior management and take their inputs
- d) Review the previous audit reports

Q.No.6 What are the types of Internal Controls

- a) Asses, Remove and Protect
- b) Analyze, Design Process, Implement
- c) Qualitative and Quantitative
- d) Preventive, Detective, Reactive

Q.No.7 Which of the following is the most important phase of implementing information security?

- a) Defining various security policies
- b) Creating Service Level Agreements
- c) Performing Risk analysis
- d) Planning Audit activities

Q.No.8 Reactive Internal Control is also called as

- a) Preventive Control
- b) Proactive Control
- c) Corrective Control
- d) Detection Control

Q.No.9 Logging all activities for later analysis is a

- a) Corrective Control
- b) Preventive Control
- c) Detective Control
- d) Proactive Control

Q.No.10 Which of the following is the right Audit Process?

- a) Planning, Assesment, Follow-up and Reporting
- b) Planning, Assesment, Reporting, Documenting
- c) Planning, Design, Testing, Implementation
- d) Planning, Assesment, Reporting, Follow-up

Q.No.11 Which type of control the security policy is?

- a) Physical Preventive Control
- b) Technical Preventive Control
- c) Administrative Detective Control
- d) Administrative Preventive Control

Q.No.12 How often should a business continuity plan be tested?

- a) Whenever there are significant changes in the organization
- b) Every Month
- c) Half Yearly
- d) Every three years

Q.No. 13 Choose the correct order:

- a) Risk Quantification, Risk Management, Risk Treatment
- b) Risk Analysis, Risk Quantification, Risk Treatment
- c) Risk Management, Risk Quantification, Risk Analysis
- d) Risk Analysis, Risk Management, Risk Quantification

Q.No.14 Which are the activities done during Audit Planning?

- a) Field Work, Evaluation and Testing
- b) Confirmation of planned actions, Audit Response verification
- c) Internal Control questionnaire, Audit scopes, Objectives
- d) Communication, Audit findings, Assesment results

Q.No. 15 Which of the following is a Security Audit Tool?

- a) nmap
- b) uname
- c) cat /etc/passwd
- d) /var/log/messages

Q.No. 16 A method of evaluating the security of a computer system or network by simulating an attack by a hacker is called as?

- a) Incident Test
- b) Security Test
- c) Network Test
- d) Penetration Test

Q.No. 17 Internal Information Security Auditor can _____.

- a) Provide suggestion on implementing control
- b) Configure the system to implement the control
- c) Write code for implementing control
- d) Take care of operating the control

Q.No. 18 Which of this data gathering technique is most important in auditing?

- a) Review earlier audit reports
- b) Interview employees based on audit questionnaire
- c) Use various tools for system auditing
- d) Review documents like policies, old audit reports etc.

Q.No. 19 Define Risk

- a) The probability that a particular threat will exploit a particular vulnerability
- b) Business is all about Risk and Reward
- c) The probability that a particular vulnerability will exploit a particular threat
- d) Risk is loss of money

Q.No.20 What are the three Risk based approaches?

- a) Identify, Remove and Restore
- b) Accept, Mitigate, Transfer
- c) Analyze, Accept and Resolve
- d) Analyze, Resolve and Restore

Q.No. 21 An Indian Company opening a branch in Japan where earthquake is more often – This risk shall be

- a) Not accepted
- b) Accepted
- c) Mitigated
- d) Transferred

Q.No. 22 A HeartBleed OpenSSL bug in Payment Gateway services company – This risk should be

- a) Accepted
- b) Analyzed
- c) Transfer to OpenSSL Development community
- d) Mitigated

Q.No. 23 Select the best option which describes Risk Management:

- a) Identifying Risks
- b) Treating Risks
- c) Analyzing
- d) All of the above

Q.No.24. As an auditor you visit an organization for auditing and observe that the organization used USB pen drives to carry valuable data from one branch to another branch. Which following control you will suggest for the organization?

- a) **Encrypt the data on the pen drive with strong encryption software.**
- b) Management should use courier service for sending pen drives to branch offices
- c) Use windows Encrypting File System.
- d) Take some money as deposit from employee who carries the pen drive and if he loses the pen drive money will not be refunded to the employee

Q.No.25. During auditing you find that an organization is using real customer data for testing new application. Which of the following will be your recommendation on this issue?

- a) perform data sanitization
- b) Ensure customer data is encrypted**
- c) Review the access rights
- d) Allow the database management to the local administrator only.

Q.No. 26 If an Auditor wants to express an opinion, then he should have

- a) Necessary qualification
- b) Audit Evidence**
- c) Audit Recommendation
- d) Audit questionnaire

Q.No. 27 Which of the following best defines Audit Sampling

- a) Take samples for work
- b) Select only few projects in an organization
- c) Applying audit procedures to less than 100% items inside a relevant population
- d) Choose all possible samples and perform audit process

Q.No. 28 What does Audit Sampling lead to

- a) Perfect Audit outcome
- b) Better Audit recommendations
- c) Audit Failure
- d) Audit Sampling risk.

Q.No. 29 Which of the following is the major requirement for the OS auditing?

- a) OS usually have a lot of security flaws
- b) OS is the main component of the system and it hosts other applications
- c) OS is the biggest software on the system
- d) OS is frequently upgraded by the manufacturer.

Q.No. 30 Which of the following file holds the user password policy settings for a Linux operating system?

- a) /etc/inittab
- b) /etc/fstab
- c) /etc/login.defs
- d) /etc/security

Q.No.31 Which of the following is basic Risk Management Process?

- a) Risk Analysis, Develop Plan, Take Action, Measure Results
- b) Risk Analysis, Mitigate and Report
- c) Risk identification, Resolving and Documenting
- d) Risk Analysis, Develop Plan and Mitigate it

Q.No. 32 What are the various Threats to IT Systems?

- a) Ex-employees
- b) Social, Environment and Technical
- c) Competitors
- d) Security

Q.No. 33 Which of the following solution will allow you to immediately recover from a physical hard disk failure and access data?

- a) Backup
- b) RAID
- c) Backup at remote site
- d) A new spare hard disk

Q.No 34 Which of the following is true about the qualitative risk analysis?

- a) It uses ratings such as High, Medium, and Low to tag the assets
- b) It uses terms like Single Loss Expectancy, Safeguard Value etc.

- c) It uses the cost of the assets
- d) It uses mathematical formulas to calculate the loss due to a risk

Q.No 35 Which of the following is not true about the quantitative risk analysis method?

- a) It uses the cost of the assets
- b) It uses ratings such as High, Medium, and Low to tag the assets
- c) It uses mathematical formulas to calculate the loss due to a risk
- d) It uses terms like Single Loss Expectancy, Safeguard Value etc.

Q.No. 36 ISO 27001:2005 is a

- a) Process
- b) Procedure
- c) Standard
- d) Best Practice

Q.No. 37 According ISO 27001:2005....

- a) Documented procedure is required only for corrective action
- b) Documented procedure is required only for preventive action
- c) Documented procedure is required only for ISMS audits
- d) Documented procedure is required for both corrective and preventive action.

Q.No. 38 Which of the following is the most important document that provides information about how ISO 27001 is implemented in that organization?

- a) Start of Agreement
- b) Source of Agreement
- c) Source of Authority
- d) Statement of Applicability

Q.No. 39 Which of the following command displays the high resource consuming processes on a Linux system?

- a) top
- b) ps aux
- c) pgrep
- d) kill

Q.No. 40 Which of the following tool allows parsing and querying Logs using SQL statements?

- a) Log Scanner on Windows
- b) Log Parser on Windows
- c) Cat /var/log/messages
- d) Log server

